

AI RESPONSIBLE PRODUCT ASSESSMENT

AI Responsible Product Assessment

Responsible AI & Governance Assessment - Framework & User Guide

Framework v0.4 · Risk Engine v0.1 · Scoring v0.1

This document describes the concept, methodology, and usage of a Responsible AI & governance assessment tool.

Table of Contents

1. Executive Summary	4
2. Purpose & Positioning	5
2.1 The problem with “is this AI ethical?”	5
2.2 What the tool is	5
2.3 What the tool is not	5
3. Scope & Target Users	6
3.1 Who this is for	6
3.2 Types of systems in scope	6
3.3 Roadmap: beyond evidence-based assessment	6
4. The Assessment Framework	7
4.1 The 18 domains	7
4.2 Evidence, not assertions	9
4.3 Every finding gets one of five statuses	9
4.4 Not every gap is equally serious	9
5. Risk & Context Classification Engine	10
5.1 Risk tier: the highest trigger wins, not an average	10
5.2 EU AI Act classification	10
5.3 What this changes in practice	10
6. Regulatory Alignment	11
7. Scoring	12
7.1 Not every gap counts the same	12
7.2 The verdict	12
7.3 The blocking gate	12
8. The Role of AI in This Tool	13
9. How It Works - Step-by-Step Guide	14
9.1 Step 1 - Intake	14
9.2 Step 2 - Risk & Applicability Profile	14
9.3 Step 3 - Evidence Review	14
9.4 Step 4 - Report	14
10. Current Scope & Roadmap	15

10.1 What's built 15

10.2 What's not built yet 15

11. Appendix A - Glossary 16

12. Appendix B - Foundational Standards Referenced 17

1. Executive Summary

This is an AI Responsible Product Assessment tool: it evaluates an AI-powered system against defined Responsible AI, governance, and regulatory controls, identifies evidence-backed gaps, and produces remediation recommendations. It does not attempt to determine whether an AI system is “ethical.” It determines how well-documented and controlled a system is relative to recognized practice, and is explicit about what could not be verified.

The core positioning statement

“This tool assesses the responsible-AI and governance maturity of an AI system against defined standards, policies, and risk controls; identifies evidence-backed gaps; and recommends remediation.”

At a glance, the tool does four things:

- Classifies risk deterministically. A short intake produces a risk tier and an EU AI Act classification using fixed rules - no model judgment.
- Scopes the assessment to context. A credit-scoring engine and an internal meeting-summarizer are not assessed against the same checklist.
- Requires evidence, not assertions. Every control resolves to Pass, Partial, Fail, Unable to assess, or Not applicable - missing evidence is never silently treated as a pass.
- Separates AI assistance from AI judgment. A language model may propose evidence mappings; it never sets a final status without human confirmation, and never computes a score.

2. Purpose & Positioning

2.1 The problem with “is this AI ethical?”

“Ethical” is not a measurable property - it's a value judgment that different stakeholders can reasonably disagree on. A tool that outputs “Ethics score: 76/100” manufactures false confidence: it implies a single objective answer exists, and hides which specific controls are missing and why they matter.

This tool is built around a narrower, more defensible claim: it evaluates whether specific, named controls - drawn from recognized frameworks - are documented and evidenced for a given system. That is measurable and auditable, without requiring the tool to adjudicate contested ethical questions.

2.2 What the tool is

- An assessment engine evaluating an AI system against defined standards, controls, and risk requirements.
- A gap-identification tool distinguishing verified evidence from developer claims from simple absence of information.
- A remediation-recommendation engine tying every finding to a specific, actionable next step.
- A risk-tiering engine that scopes assessment depth to the system's actual context and consequences.

2.3 What the tool is not

- Not an ethics adjudicator - it does not determine whether a use case is morally acceptable.
- Not a legal compliance certification - regulatory mapping (Section 6) is a traceability aid, not legal advice.
- Not a fully automated black box - deterministic rules and required human confirmation are structural, not incidental (Section 7).

3. Scope & Target Users

3.1 Who this is for

- AI, product, and compliance teams assessing their own systems pre-deployment or pre-audit.
- Governance and risk teams reviewing AI systems entering an organization.
- Procurement and vendor-risk teams assessing third-party AI before adoption.

3.2 Types of systems in scope

The framework generalizes across AI system types and industries: automation tools, data extraction and analysis systems, generative AI applications, prediction/classification/recommendation systems, decision-support systems, and financial AI (fraud detection, credit assessment, trading). Current demonstration scenarios focus on financial services, given its regulatory density (Section 6), but the domain/criteria structure is industry-agnostic by design.

3.3 Roadmap: beyond evidence-based assessment

The current tool assesses a system from documentation and evidence a team supplies directly. Two extensions are planned: assessing systems from publicly available material alone (a website's privacy policy, published model card) where internal controls default to “Unable to assess” rather than a pass; and a machine-readable policy-gate format for CI/CD pipelines (Section 9).

4. The Assessment Framework

The framework defines 18 governance domains, each broken into individually-scored criteria. Every criterion specifies exactly what evidence would satisfy it - the assessment never asks a bare yes/no question.

4.1 The 18 domains

Domains group into two rollups used in scoring (Section 7): Governance domains cover process, accountability, and documentation; Responsible AI domains cover the system's actual behavior and impact. Not every domain applies to every system - applicability is set by the Risk & Context Classification Engine (Section 5).

Domain	Rollup	What it covers
Governance & Accountability	Governance	Named ownership, formal risk classification, sign-off before deployment.
Risk Management	Governance	Documented risk assessment covering intended and foreseeable misuse.
Data Governance & Data Quality	Governance	Provenance, quality checks, and licensing of training data.
Privacy & Data Protection	Governance	Legitimate purpose, retention, data-subject rights.
Fairness & Bias	Responsible AI	Subgroup performance testing, thresholds, mitigation plans.
Transparency & Disclosure	Responsible AI	Users informed they're interacting with AI; limitations disclosed.
Explainability & Interpretability	Responsible AI	A mechanism exists to explain individual outputs.
Human Oversight	Responsible AI	A human review/override mechanism exists and is used.
Security & Resilience	Responsible AI	Standard + AI-specific security controls.
Safety	Responsible AI	Foreseeable-harm assessment, guardrails, escalation path.
Robustness & Reliability	Responsible AI	Edge-case testing; tracked accuracy / error-rate metrics.
Model & System Documentation	Governance	A current model/system card; documented limitations.
Monitoring & Continuous Evaluation	Responsible AI	Production performance and drift monitoring.
Incident Management	Responsible AI	An AI-specific incident process; a user reporting channel.
Third-Party & Vendor AI Risk	Responsible AI	Inventory and risk assessment of third-party AI components.

Domain	Rollup	What it covers
Change & Version Management	Governance	Change review/approval and rollback capability.
Regulatory Alignment (EU AI Act)	Governance	Legal-obligation overlay - see Section 6.
User & Stakeholder Impact	Responsible AI	Impact assessment and a mechanism to contest outcomes.

4.2 Evidence, not assertions

Every criterion asks what evidence would demonstrate it - not just whether a policy “exists.” For example, PRIV-01 (Privacy & Data Protection) requires a defined legitimate purpose for personal-data processing, evidenced by a privacy impact assessment or data inventory - and a finding might read: “Partial - retention is documented for customer data but not for derived AI outputs.” Each criterion carries a permanent ID (e.g. FAIR-01) that never changes once assigned.

4.3 Every finding gets one of five statuses

This is the single most important design decision in the framework: it prevents an absence of information from silently becoming a pass.

Status	Meaning
Pass	Evidence directly verifies the requirement is met.
Partial	Evidence exists but is incomplete or only partly satisfies the requirement.
Fail	Evidence directly shows the requirement is not met.
Unable to assess	No evidence was available - never scored as a pass.
Not applicable	Excluded for this system type - requires a logged justification; never silent.

Rule: missing evidence is never a pass

For assessments based on public material alone, most internal-control criteria default to “Unable to assess” unless the organization has actually published evidence. The tool must never infer a pass from silence.

4.4 Not every gap is equally serious

Each criterion also carries a default severity - Critical, High, Medium, or Low - reflecting how serious a failure would be (e.g. no human oversight for an automated credit decision is Critical; a missing changelog field is Low). Severity feeds directly into scoring (Section 7), so a handful of load-bearing gaps can't get diluted by many minor ones.

5. Risk & Context Classification Engine

The framework does not apply the same checklist to every system. A credit-scoring engine and an internal meeting-summary tool warrant very different depths of scrutiny. Before any evidence is reviewed, a short intake - what the system does, who it affects, what data it uses, and its worst realistic failure consequence - determines which domains and criteria actually apply.

This classification is fully deterministic: fixed rules, no language-model judgment. A legal obligation or governance requirement shouldn't vary with model output.

5.1 Risk tier: the highest trigger wins, not an average

The overall risk tier is set by whichever single answer is most severe - never a blended average. Risk from one critical dimension (e.g. a safety-critical failure mode) should never be diluted by several low-risk answers elsewhere. A credit-scoring engine typically converges on “High” from several independent signals at once - which is exactly the kind of overdetermined result that's easy to defend to a skeptical reviewer.

5.2 EU AI Act classification

Where the system has any EU nexus, the same intake also determines its EU AI Act status: whether it matches a prohibited practice (Article 5 - halts the assessment entirely), a high-risk Annex III use case (e.g. credit scoring, employment decisions), a limited-risk system with transparency obligations, or minimal risk. A claimed narrow-task exemption is only honored if documented - undocumented claims default back to high-risk, the same “no evidence, no benefit of the doubt” principle used throughout.

5.3 What this changes in practice

Once risk and EU AI Act status are set, each of the 18 domains resolves to Mandatory, Recommended, or Not Applicable for that specific system. Where the EU AI Act imposes a binding high-risk obligation, several domains - Risk Management, Data Governance, Fairness, Human Oversight, Security, Robustness, Documentation, and Regulatory Alignment - are forced to Mandatory regardless of the general risk tier, because those Articles are legal requirements, not maturity recommendations.

6. Regulatory Alignment

Rather than inventing proprietary ethical criteria, the framework maps to recognized standards. NIST AI RMF (Govern / Map / Measure / Manage) is the structural backbone - its four functions map cleanly onto the Governance, Risk, Documentation, and Monitoring domains. OECD AI Principles and ISO/IEC 42001 are planned as an additional overlay once the core criteria are further validated.

The EU AI Act is fully incorporated now, not deferred: its high-risk obligations reached full applicability in August 2026, and its Annex III explicitly names credit scoring and insurance pricing - directly overlapping common financial-services use cases. It's treated as a legal-obligation overlay: it doesn't restructure the domains in Section 4, it adds a parallel "is this legally required" lens on top of criteria that already exist for maturity reasons. A handful of criteria map directly to specific articles - for example, human oversight controls to Article 14, data governance to Article 10, and incident reporting to Article 73.

The prohibited-practice check is a hard gate, not a normal score

If a system matches an Article 5 prohibited practice, the assessment halts - no percentage score is produced, because a numeric score on a system that cannot legally be deployed would itself be misleading. See Section 7.

7. Scoring

Three things are reported per assessment, deliberately kept separate rather than collapsed into a single “ethics score” - because they answer different questions, and merging them would reintroduce exactly the false confidence this tool is designed to avoid.

What's reported	Question it answers
Readiness (%)	Of what was assessable, how much is actually in good shape?
Confidence (%)	How much of that is backed by real evidence, versus defaulted low due to missing evidence?
Verdict	Independent of the percentages - is this system's current state safe to deploy as assessed?

A system can score 80% readiness with 40% confidence - a very different situation from 80% with 95% confidence. The report never merges these into one number.

7.1 Not every gap counts the same

A missing Critical control on a system where that control is legally or safety mandatory weighs far more than a missing Low-severity, optional one. Readiness percentages are weighted accordingly, so failing one load-bearing control moves the score far more than a missing nice-to-have.

7.2 The verdict

The verdict shown at the top of the report - Pass / Medium / High / Critical - reflects what the assessment actually found, and is deliberately kept separate from the system's inherent risk category from Section 5. A system that is inherently “high-risk” by category (e.g. a credit-scoring engine) can still receive a Pass verdict if every mandatory control is genuinely in place - the inherent category is shown as context, never conflated with the outcome.

Verdict	What it means
Critical	A critical-severity gap exists.
High	No critical gap, but a high-severity one exists.
Medium	Only lower-severity gaps exist, or overall readiness is below 85%.
Pass	No gaps found, and readiness is at or above 85%.

7.3 The blocking gate

If a system matches an EU AI Act Article 5 prohibited practice, normal scoring stops entirely. The report shows only the matched category, the evidence, and required remediation - no readiness percentages or scorecard. A percentage score on a system that legally cannot be deployed would be misleading, not just unhelpful.

8. The Role of AI in This Tool

The founding principle: AI assists the assessment engine, it does not become the assessment engine. A tool whose value rests on grounded, evidence-based governance assessment can't itself rest on an ungrounded model judgment.

The AI does	The AI does not
Read uploaded documentation and propose which evidence maps to which criterion.	Assign a Pass / Partial / Fail status directly, or decide risk tier or domain applicability.
Flag likely gaps in plain language for a human to confirm.	Compute scores, weights, or readiness percentages - that's fixed arithmetic, never model output.
Draft remediation text and the executive summary from already-confirmed findings.	Decide whether evidence is "close enough" to count - a human confirms every mapping.

Concretely

The AI proposes something like: Partial - "evidence mentions retention for customer data, silent on AI-derived outputs." A human explicitly accepts or rejects that before it's written into the scored record. Nothing the AI proposes is ever auto-committed.

9. How It Works - Step-by-Step Guide

9.1 Step 1 - Intake

Answer a short set of questions: what the system does, who it affects, what data it processes, and its EU nexus. Two demo scenarios are preloaded for quick testing - a high-risk credit engine and a low-risk internal summarizer - selectable with one click instead of typing through the form.

9.2 Step 2 - Risk & Applicability Profile

The engine computes the risk tier and EU AI Act tier automatically, and lists the resulting domain applicability for all 18 domains, each with a visible reason. If the system matches a prohibited practice, a blocking warning appears here, before any evidence review begins.

9.3 Step 3 - Evidence Review

This is the core of the assessment. Two ways to supply evidence:

- Upload documents - PDF, Word, or plain text/Markdown files (privacy policies, model cards, risk assessments, evaluation reports).
- Paste text directly - always available, and the more reliable path.

Once documents are supplied, running the AI evidence mapper reads them domain by domain and proposes a status and short rationale for each criterion. Each proposal appears with Accept and Dismiss controls - nothing is scored until explicitly accepted. Criteria can also be marked manually at any time. Marking a criterion Not applicable requires typing a justification - the interface will not accept a silent exclusion.

9.4 Step 4 - Report

The report shows, in order: the assessment verdict, the system's inherent risk classification shown separately as context, readiness and confidence percentages, findings by severity, the full domain scorecard, and an auto-generated remediation list sorted by severity. A download option produces a shareable, self-contained copy of the same report.

10. Current Scope & Roadmap

In the interest of the same evidence-based honesty this tool asks of the systems it assesses, this section states plainly what the current version does and does not do.

10.1 What's built

- A complete, internally consistent framework: 18 domains, ~74 criteria, and severity tags.
- A working, testable tool covering the full pipeline end to end, including the EU AI Act blocking gate, file upload and parsing, and AI-assisted evidence mapping with mandatory human confirmation.

10.2 What's not built yet

Item	Detail
Persistence	No database - assessments exist only in-session and are lost on refresh.
Criteria depth	A representative subset of criteria per domain, not yet the full eventual library.
Public-material assessment	Assessing a system from its public web presence alone is planned but not yet built.
CI/CD integration	A machine-readable policy-gate format is conceptual only (Section 9 roadmap).
Full standards mapping	EU AI Act is fully mapped; OECD and ISO/IEC 42001 overlays are not yet built.
Legal review	Nothing here constitutes legal advice or a compliance certification - regulatory mapping is a traceability aid only (Section 2.3).

11. Appendix A - Glossary

Term	Definition
Mandatory / Recommended	Applicability levels assigned per system by the classification engine - not fixed per domain.
Readiness (%)	How much of what was assessable in a domain is actually in good shape.
Confidence (%)	How much of the readiness score rests on real evidence versus criteria marked Unable to assess.
Inherent risk tier	The system's baseline risk classification from intake - what kind of system it is, independent of assessment findings.
Assessment verdict	The actual outcome of this specific assessment - kept separate from the inherent risk tier.
Blocking gate	The Article 5 prohibited-practice check; a match halts scoring entirely.
Criterion ID	A permanent identifier (e.g. FAIR-01), never renumbered once assigned.
Annex III	The EU AI Act's list of high-risk use-case categories, including credit scoring and insurance pricing.
GPAI	General-purpose AI model - a third-party foundation model incorporated into the assessed system.

12. Appendix B - Foundational Standards Referenced

Standard / Regulation	Role in this framework
NIST AI Risk Management Framework	Structural backbone - its four functions map onto the domain structure.
EU AI Act	Fully incorporated legal-obligation overlay, including the prohibited-practice gate, high-risk obligations, and transparency requirements.
OECD AI Principles	Referenced foundation; mapping layer not yet built.
ISO/IEC 42001 (AI Management Systems)	Referenced foundation; mapping layer not yet built.

This document is a working reference for an assessment tool under active development. Section references throughout correspond to the underlying Framework, Risk Classification Engine, and Scoring Methodology design documents.